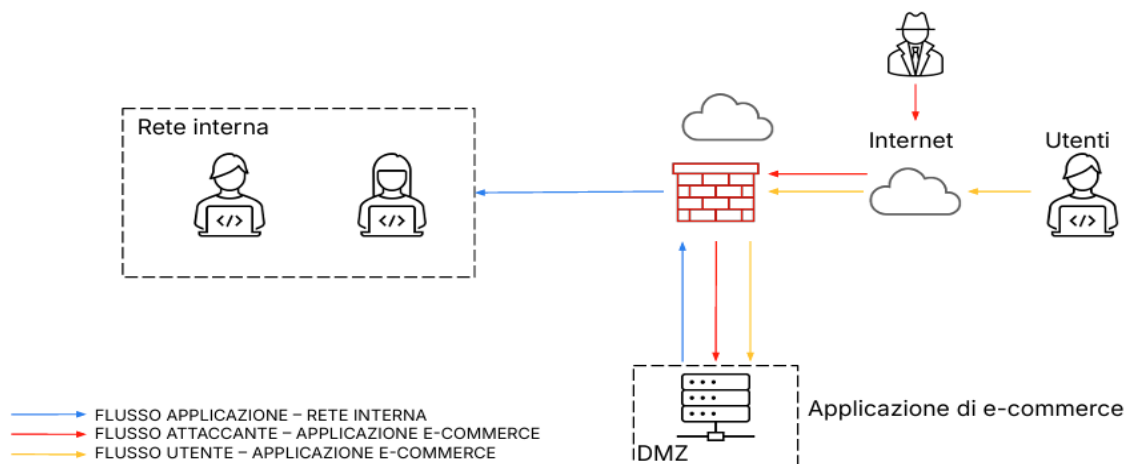


Traccia

Esercizio Traccia e requisiti Con riferimento alla figura in slide 2, rispondere ai seguenti quesiti.

1. **Azioni preventive:** quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni 2
2. **Impatti sul business:** l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica 3
3. **Response:** l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta



Architettura di rete: L'applicazione di e-commerce deve essere disponibile per gli utenti tramite Internet per effettuare acquisti sulla piattaforma. La rete interna è raggiungibile dalla DMZ per via delle policy sul firewall, quindi se il server in DMZ viene compromesso potenzialmente un attaccante potrebbe raggiungere la rete interna.

Per la prevenzione e protezione esterna da SQLi e XSS opterei per:

WAF + CSP

- **Posizione:** tra Internet e il firewall/DMZ.
- **Funzione:** intercetta e filtra le richieste HTTP per proteggere da attacchi tipo SQLi, XSS, ecc.
- **CSP** (Content Security Policy) aggiunge protezione lato browser impedendo esecuzioni di script non autorizzati.

Cos'è un WAF ?

Un WAF è un sistema di sicurezza progettato per monitorare, filtrare e bloccare il traffico HTTP/HTTPS diretto a (e da) un'applicazione web, al fine di proteggere l'applicazione da attacchi informatici.

Cosa fa un WAF ?

Un WAF analizza il traffico web in tempo reale e applica regole di sicurezza per:

- Bloccare SQL injection
- Fermare Cross-Site Scripting (XSS)
- Proteggere da attacchi Cross-Site Request Forgery (CSRF)
- Impedire iniezioni di comandi o file inclusion
- Mitigare attacchi DDoS (in parte)
- Rilevare bot malevoli e crawler

Tipologie di WAF

- Basati su rete (Hardware): Installati fisicamente vicino al server web
- Basati su software: Esempi open source come ModSecurity
- Basati su cloud: Offerti da provider come Cloudflare, AWS WAF, Akamai, Imperva

Esempi pratici

- Un utente prova a eseguire UNION SELECT su un campo di login → il WAF lo rileva come tentativo di SQL Injection e blocca la richiesta.

- Un bot tenta di inviare 1000 richieste al secondo → il WAF può attivare rate-limiting o CAPTCHA.

Vantaggi

- Protezione immediata da vulnerabilità note
- Log e auditing del traffico sospetto
- Configurazioni flessibili (regole personalizzate)

Limiti

- Non sostituisce la scrittura sicura del codice
- Può generare falsi positivi
- Alcuni attacchi sofisticati possono bypassarlo

Content Security Policy (CSP)

È una politica di sicurezza implementata nei browser web per prevenire attacchi come:

- Cross-Site Scripting (XSS)
- Data injection
- Clickjacking

Cos'è?

La **CSP** è un header HTTP (es. Content-Security-Policy) che specifica quali risorse (script, immagini, fogli di stile, ecc.) possono essere caricate ed eseguite da una pagina web.

Esempio pratico

http

Content-Security-Policy: default-src 'self'; script-src 'self' https://apis.google.com

Significa:

- Carica contenuti solo dallo stesso dominio ('self')
- Gli script sono ammessi solo dal dominio locale e da https://apis.google.com

Vantaggi

- Protegge contro XSS impedendo l'esecuzione di script non autorizzati
- Limita l'impatto di estensioni maligne o contenuti embedded non controllati
- Aumenta il controllo sul comportamento della pagina web

Attenzione

- Una CSP troppo restrittiva può rompere il sito se blocca risorse legittime
- È importante testarla bene prima di applicarla in produzione.

Protezione DDoS:

Modulo DDoS Protection

- **Posizione:** subito dopo il **WAF**.
- **Funzione:** blocca o mitiga grandi volumi di traffico sospetto che potrebbero rendere l'applicazione irraggiungibile.
- **Beneficio:** evita perdite economiche da downtime, come calcolato (1.500 €/minuto).

Un DDoS (Distributed Denial of Service) è un tipo di attacco informatico che mira a rendere un servizio online non disponibile, sovraccaricandolo con una quantità enorme di richieste.

Significato

DDoS = Distributed Denial of Service

"Distributed" perché l'attacco proviene da molteplici dispositivi (spesso una botnet di computer infetti).

Come funziona

1. Un hacker prende il controllo di migliaia di dispositivi (PC, server, IoT, ecc.).
2. Li comanda per inviare masse di traffico verso un sito web o server.

3. Il server bersaglio si sovraccarica e non riesce più a rispondere a utenti legittimi.

Tipi comuni di attacchi DDoS

Tipo	Descrizione breve
Volumetrici	Sovraccaricano la banda (es. UDP flood)
Protocol-based	Sfruttano vulnerabilità nei protocolli (es. SYN flood)
Application-layer	Colpiscono risorse web specifiche (es. HTTP GET flood)

Effetti

- Siti web inaccessibili
- Perdite economiche e di reputazione
- Possibili vulnerabilità secondarie sfruttabili durante il caos

Contromisure

- **WAF** (Web Application Firewall)
- CDN con protezione DDoS (es. Cloudflare, Akamai)
- Rate limiting e IP filtering
- Sistemi di rilevamento e mitigazione automatici

Malware e isolamento automatico

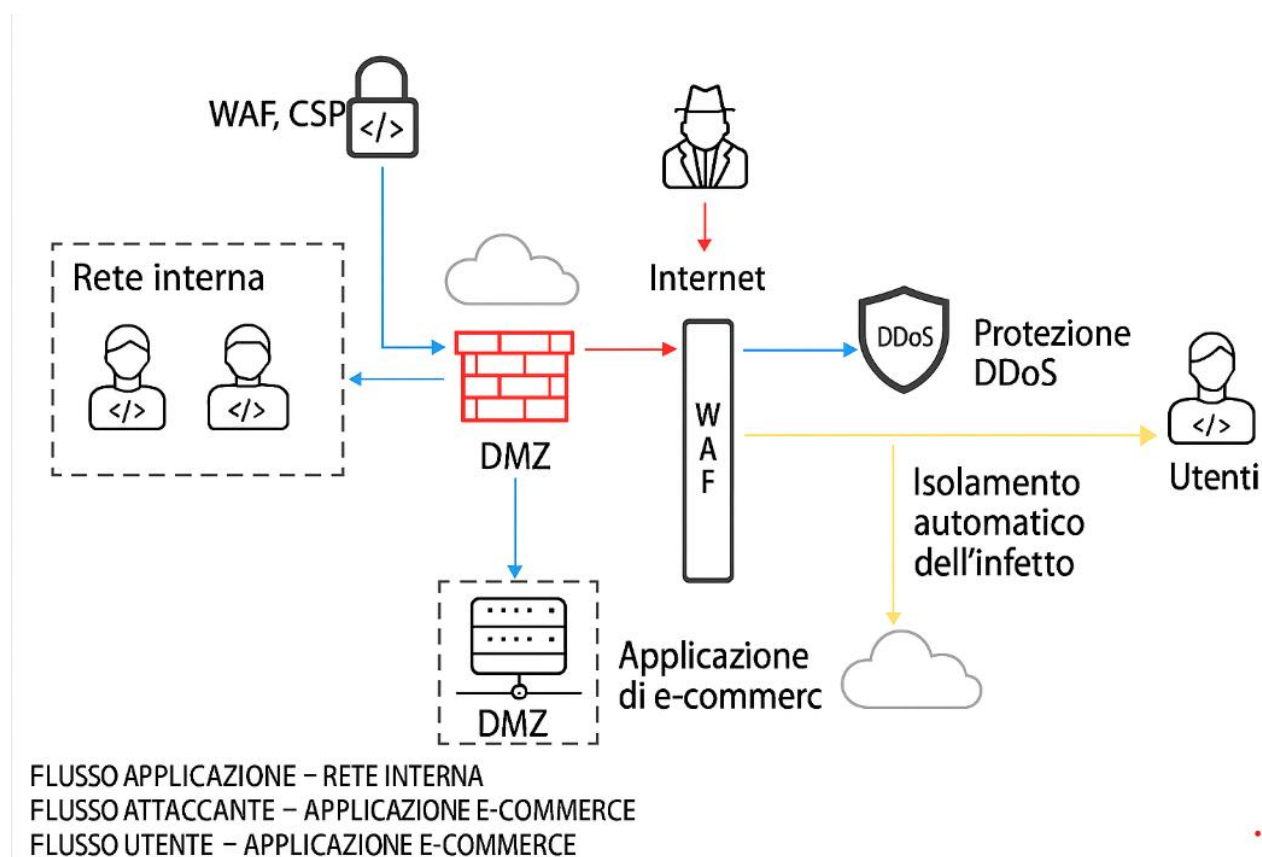
Isolamento automatico dell'infecto

- **Nuovo componente:** rappresenta un sistema EDR/IPS/NAC che rileva comportamenti anomali nella macchina compromessa.
- **Funzione:**
 - Interrompe il traffico in uscita dalla macchina e-commerce.
 - Evita lateral movement verso la rete interna.
 - Può attivare automaticamente l'isolamento della macchina infetta, escludendola dal traffico di rete.

Firewall e DMZ

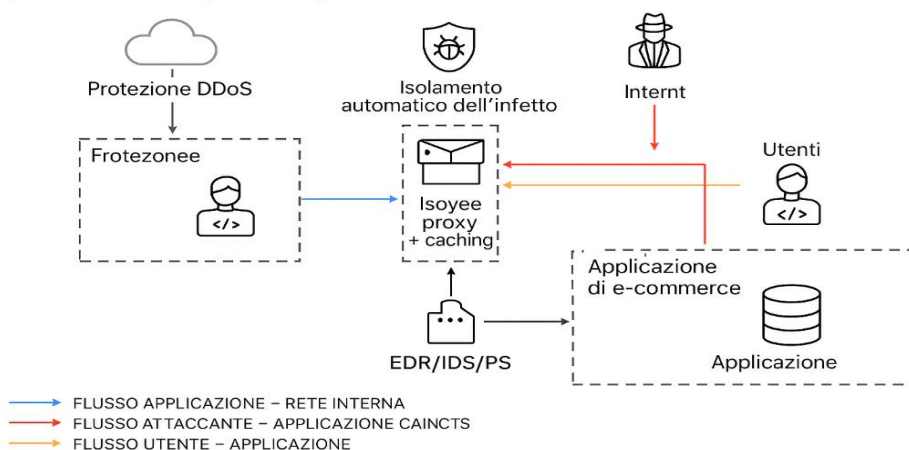
- La **DMZ** (zona demilitarizzata) contiene l'app e-commerce.
- Il firewall delimita i confini tra:
 - Internet ↔ **DMZ** (regolato da **WAF**)
 - **DMZ** ↔ Rete interna (accesso limitato e loggato).

(Nell'immagine sottostante è presente una rappresentazione schematica di ciò che è stato fatto)



Architettura di rete

L'applicazione di e-commerce deve essere disponibile per gli utenti tramite Internet per effettuare acquisti sulla piattaforma.



Utenti legittimi:

- Flusso in giallo: mostra il normale accesso degli utenti all'app di e-commerce.
- Gli utenti passano attraverso:
 - Internet → DDoS Protection → WAF → App in DMZ

Attaccante:

- Flusso in rosso: illustra un potenziale attacco proveniente da Internet.
- Se il traffico supera il WAF e la protezione DDoS (es. malware zero-day), può colpire la macchina nella DMZ.

Flusso applicazione – rete interna:

- Flusso in blu: consente comunicazione dell'app in DMZ con la rete interna, ma in modo controllato.
- Con policy firewall restrittive e monitoraggio, il traffico è limitato e tracciato.
- In uno scenario ottimale, si potrebbe eliminare del tutto questo canale, separando completamente le zone.

In sintesi

Ora ho:

- Protezione preventiva contro vulnerabilità comuni (WAF, CSP, validation).
- Protezione contro DDoS (evita danni economici).
- Contenimento automatico in caso di compromissione (isolamento macchina infetta).
- Segmentazione di rete e firewall con policy strette.

Una volta capita la struttura e la prevenzione da effettuare diamo uno sguardo a tutti gli strumenti open source e commerciali per ogni area di sicurezza trattata per l'e-commerce:

Prevenzione di SQL Injection e XSS (WAF, validazione, CSP)

Open Source:

- **ModSecurity** – WAF potente e personalizzabile.
- **OWASP CRS** – Regole di sicurezza per ModSecurity.
- **ZAP Proxy** – Strumento di scanning automatico per vulnerabilità (OWASP).
- **Naxsi** – WAF per NGINX.
- **PHPIDS** – Sistema di rilevamento intrusione per input.

Commerciali:

- **F5 Advanced WAF** – Soluzione enterprise con protezione comportamentale.
- **Cloudflare WAF** – SaaS con protezione immediata da SQLi/XSS.
- **Imperva WAF** – Protezione multilivello per web app e API.
- **Barracuda WAF** – Protezione avanzata per traffico HTTP/S.

Protezione da attacchi DDoS

Open Source:

- **Fail2Ban** – Blocca IP sospetti in base ai log.
- **NGINX rate limiting** – Limita richieste HTTP al server.
- **iptables + tc** – Per shaping e filtraggio del traffico.

Commerciali:

- **Cloudflare DDoS Protection** – Mitigazione globale layer 3-7.
- **AWS Shield (Standard / Advanced)** – Protezione gestita contro DDoS.
- **Akamai Kona Site Defender** – Rete distribuita per difesa scalabile.
- **Radware DefensePro** – Mitigazione real-time di attacchi volumetrici.

Firewall, Segmentazione e Isolamento (DMZ, NAC)

Open Source:

- **pfSense** – Firewall/router open source con supporto DMZ.
- **OPNsense** – Alternativa moderna a pfSense con IDS integrato.
- **Netfilter/iptables** – Gestione avanzata del traffico in Linux.
- **OpenNAC** – Controllo accessi alla rete.

Commerciali:

- **Fortinet FortiGate** – Firewall di nuova generazione con protezione perimetrale.
- **Palo Alto Networks NGFW** – Firewall avanzato con policy dettagliate.
- **Cisco Firepower** – Ispezione e segmentazione dettagliata del traffico.
- **Aruba ClearPass** – NAC avanzato per isolamento dispositivi compromessi.

Rilevamento e risposta a malware / compromissione

Open Source:

- **Wazuh** – SIEM e sistema EDR con monitoraggio in tempo reale.
- **Suricata** – IDS/IPS basato su regole.
- **OSSEC** – Monitoraggio integrità file + log.
- **Snort** – IDS/IPS flessibile.

Commerciali:

- **CrowdStrike Falcon** – EDR cloud-native con risposta automatica.
- **SentinelOne** – EDR con funzionalità di rollback.
- **Sophos Intercept X** – Anti-malware e contenimento automatico.
- **Cisco Secure Endpoint** – Protezione endpoint gestita.

Reverse Proxy, Caching, Bilanciamento

Open Source:

- **NGINX** – Proxy, caching e load balancing.

- **Varnish** – Acceleratore HTTP con caching avanzato.
- **HAProxy** – Bilanciamento e failover TCP/HTTP.

Commerciali:

- **Cloudflare CDN/Reverse Proxy** – Distribuzione e caching edge.
- **Fastly** – Caching dinamico e protezione edge.
- **Imperva Incapsula** – CDN + proxy + sicurezza.

Monitoraggio e analisi (SIEM, log, alerting)

Open Source:

- **ELK Stack** (Elasticsearch, Logstash, Kibana) – Analisi log e dashboard.
- **Grafana + Loki** – Visualizzazione e query di log.
- **Prometheus + Alertmanager** – Metriche + notifica alert.

Commerciali:

- **Splunk** – SIEM e analisi machine data.
- **Datadog** – Monitoraggio full-stack cloud-native.
- **IBM QRadar** – SIEM avanzato per aziende.

Una volta visti i vari strumenti ora diamo un'occhiata ai prezzi e alla miglior soluzione per una piccola e media impresa

Strumenti Open Source (gratuiti)

Categoria	Strumenti gratuiti
WAF / protezione SQLi, XSS	ModSecurity + OWASP CRS, ZAP Proxy, Naxsi, PHPIDS
Mitigazione DDoS	Fail2Ban, NGINX rate limiting, iptables + tc
Firewall / segmentazione / NAC	pfSense, OPNsense, iptables, OpenNAC
IDS/IPS / EDR	Suricata, Snort, Wazuh, OSSEC

Categoria	Strumenti gratuiti
Reverse proxy / caching / LB	NGINX, Varnish, HAProxy
Monitoring / SIEM / log	ELK Stack, Grafana+Loki, Prometheus+Alertmanager

Strumenti Commerciali (prezzi indicativi)

1. CrowdStrike Falcon (EDR)

Prezzi per endpoint (annuali):

- Falcon Go: \$59.99/device (fino a 100 dispositivi)
- Falcon Pro: \$99.99/device (mid-tier)
- Falcon Enterprise: \$184.99/device (completo di threat hunting)
- Falcon Complete MDR e Falcon Elite: prezzo su richiesta

Scenari d'uso:

- Go: piccole imprese con pochi dispositivi, protezione antivirus e controllo USB.
- Pro: medie aziende che necessitano di firewall management e protezione più robusta.
- Enterprise: per grandi organizzazioni con esigenza di EDR avanzata, XDR, threat hunting e intelligence.
- Complete MDR/Elite: servizi completamente gestiti per imprese che vogliano delegare la cybersecurity.

2. AWS Shield Advanced (DDoS Protection)

- Costo fisso: \$3.000 al mese per account o organizzazione AWS
- Costo aggiuntivo per dati trasferiti: ~\$25–50/GB DTO a seconda dei servizi (es. CloudFront, ALB)
- Impegni: abbonamento minimo annuale, include monitoraggio avanzato, AWS Shield Response Team (SRT), protezione costi, Analytics

Scenari d'uso:

- Applicazioni mission-critical con elevati requisiti di disponibilità.
- Infrastrutture cloud complesse con load balancer e CDN integrate.
- Organizzazioni che richiedono coverage enterprise contro attacchi volumetrici e applicativi.

3. AWS WAF (layer 7 firewall)

- \$5 per Web ACL al mese
- Regole personalizzate: \$1 per rule / mese
- Ispezione: \$0.60 per milione di richieste
- Bot/Fraud Control: +\$10 per Web ACL + \$1/milione req.

Esempio costi:

- 1 Web ACL + 5 regole + 10 M richieste:
→ $\$5 + \$5 + \$6 = \$16/\text{mese}$

Scenari d'uso:

- Protezione contro attacchi web (SQLi, XSS).
- Gestione programmatica dei flussi e regole avanzate basate su URL, IP, headers.
- Scalabile su distribuzioni con CloudFront e ALB.

4. Cloudflare WAF e DDoS

- Piano Pro: ~\$20-25/mese
- Piano Business: ~\$200/mese
- Enterprise: da \$15.000/mese (preventivo personalizzato)

Scenari d'uso:

- Siti e-commerce con traffico elevato.
- Servizi ad alta latenza distribuiti globalmente (edge caching e CDN).
- Organizzazioni che cercano WAF + CDN + mitigazione DDoS in una piattaforma unica.

5. Imperva WAF

- Piano Business: ~\$299/sito/mese
- Piano Enterprise: prezzo su richiesta Piccole imprese, antivirus avanzato, protezione USB
- CrowdStrike Falcon Pro EDR medio livello \$99.99/device/anno Medie aziende, EDR + threat intelligence
- CrowdStrike Falcon Ent EDR avanzato \$184.99/device/anno Grandi aziende, EDR + XDR + threat hunting + intelligence
- Shield Advanced DDoS cloud \$3.000/mese + \$25–50/GB DTO Applicazioni mission-critical; attacchi volumetrici e applicativi; SLA elevati.
- AWS WAF Web firewall \$5/Web ACL + \$1/regola + \$0.60/milione req. | Protezione personalizzata per app con regole granulare.
- Cloudflare WAF | WAF + CDN | \$20/mese (Pro) – \$200/mese (Biz), da \$15k/mese ent. Siti globali, CDN integrato, protezione a più livelli
- Imperva WAF Web firewall ~\$299/site/mese (Business); Enterprise su richiesta Web app/API complesse, reporting e compliance.

Sommario rapido

Strumento	Tipo	Prezzo indicativo
ModSecurity + OWASP CRS	Open source	Gratuito
F5 Advanced WAF	Commerciale	\$17k–25k licenza o \$1,45/ora cloud
Cloudflare WAF	Commerciale	\$20–25/mese (Pro), \$200/mese (Biz)
Imperva WAF	Commerciale	\$299/sito/mese + opzioni enterprise
CrowdStrike Falcon Go/Pro/Ent	Commerciale	\$60–185/device/anno
SentinelOne Core/Control/Comp	Commerciale	\$70–180/device/anno
ELK, Grafana, Prometheus	Open source	Gratuito
Splunk, Datadog, QRadar	Commerciale	Da preventivo personalizzato

Confronto Architetture Di Sicurezza				
	Categoria	Base	Intermedia	Aggressiva
1	DDoS/WAF	Fail2Ban + NGINX	Cloudflare Pro	Cloudflare Enterprise / AWS Shield
2	EDR / Isolamento	Nessuno o antivirus standard	CrowdStrike Falcon Pro	CrowdStrike Kubernetes/XDR
3	SIEM / Logging	Syslog o logging manuale	ELK Stack	Splunk / SumoLogic
4	Reverse Proxy	Apache/NGINX	NGINX + caching	NGINX + Kong Gateway
5	IDS / IPS	Nessuno	Suricata	Suricata / Cloud IDS
6	API Gateway	N/D	N/D	Kong / Envoy
7	Service Mesh	N/D	N/D	Istio / Cilium
8	Totale Costo Stimato (€)	0	4400	30000

Caratteristiche principali dell'architettura aggressiva:

- Zero Trust + DDoS enterprise (Cloudflare Enterprise, AWS Shield)
- API Gateway moderno + Service Mesh (Kong, Istio, Envoy)
- EDR/XDR container-aware (CrowdStrike XDR)
- SIEM enterprise (Splunk o Sumo Logic)
- Sicurezza a più livelli e monitoring approfondito

Per rendere la DMZ sicura anche senza l'uso di software Obiettivo:

Mantenere la DMZ isolata, monitorata e controllata, anche senza strumenti software avanzati.

Architettura semplice ma sicura

1. Firewall a doppia interfaccia (fisica)

- Usa due firewall fisici separati o router/firewall con più interfacce
- Configura:
 - una rete esterna (WAN) verso Internet
 - una rete DMZ isolata
 - una rete interna isolata
- Ogni flusso deve essere esplicitamente autorizzato

Esempio:

[Internet]

|

[Firewall esterno]

|

\

[DMZ]

[Firewall interno]

|

[Rete interna]

2. Regole firewall strettamente segmentate

- Consentire solo le porte necessarie (es. 80/443 TCP per il frontend)
- Vietare qualsiasi comunicazione dalla DMZ verso la rete interna a meno che non sia *esplicitamente* richiesta
- Bloccare tutto per default (default deny)

3. Accesso DMZ tramite bastion host

- Non accedere mai direttamente ai server nella DMZ
- Configura un jump server o bastion host accessibile via SSH/VPN solo da IP amministrativi autorizzati
- Anche questo deve essere isolato e monitorato

4. Log fisico e manuale

- Anche senza SIEM: scrivi log su file, forwardali su un server interno di sola lettura
- Ogni log di accesso/errore può essere controllato periodicamente

5. Hardening del server in DMZ

- Disabilita tutto ciò che non serve: servizi, porte, moduli
- Usa un utente con privilegi minimi per eseguire l'applicazione
- Blocca login diretti da root
- Attiva logging, password robuste e rotazione log

6. Aggiornamenti regolari e backup offline

- Aggiorna manualmente OS e applicazioni
- Fai backup su unità rimovibili offline per evitare ransomware

Vantaggi di questo approccio

Aspetto	Vantaggio
Semplicità	Nessuna dipendenza da software di terze parti
Controllo manuale	Hai piena consapevolezza delle regole e delle configurazioni
Isolamento forte	Il traffico tra le reti passa solo attraverso regole specifiche e fisicamente filtrate
Costo basso	Hardware economico (router/firewall anche open source tipo pfSense o OPNsense)

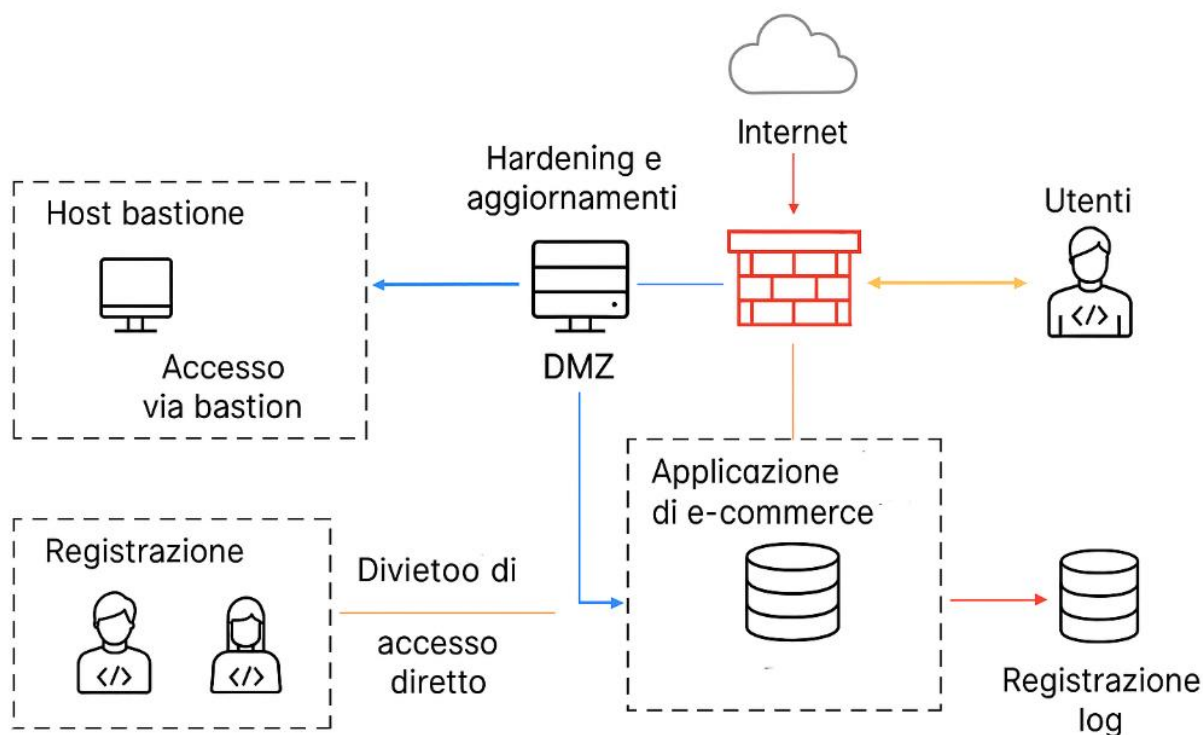
Limiti

Aspetto	Svantaggio/attenzione
Zero automazione	Nessuna risposta automatica a minacce
Visibilità ridotta	Devi analizzare manualmente i log
Scalabilità limitata	Non adatta a gestire grandi volumi di traffico o utenti simultanei
No threat intelligence	Non rileva minacce sofisticate o attacchi stealth

In sintesi: check pratico da applicare

- Firewall fisico con interfacce separate
- Accesso alla DMZ solo via Bastion
- Nessun flusso DMZ → rete interna non autorizzato
- Logging server interno (anche rudimentale)
- Configurazioni minime e aggiornate nel server DMZ

Questo può servire a mantenere la struttura sotto il completo controllo della propria attività/azienda e secondo ma non per importanza tagliare significativamente le spese di software e aziende di terze parti



Cos'è un Bastion Host (o Jump Box)?

Un Bastion Host è un server intermediario che funge da punto sicuro di accesso alle risorse critiche della rete, come i server nella DMZ o nella rete interna.

In pratica, invece di collegarti direttamente al server DMZ, passi prima dal bastion, che ha controlli di accesso forti (IP, autenticazione, logging, ecc.).

Perché è utile:

Vantaggio	Descrizione
Accesso controllato	Solo utenti autorizzati possono accedere al bastion
Logging centralizzato	Puoi loggare ogni sessione SSH o comandi digitati

Vantaggio	Descrizione
Rete più chiusa	I server DMZ non sono esposti direttamente alla rete degli admin
Multi-utente sicuro	Ogni admin si autentica col suo account (meglio se via chiave SSH)

Invece per una infrastruttura contro i DDoS senza software

Architettura e rete

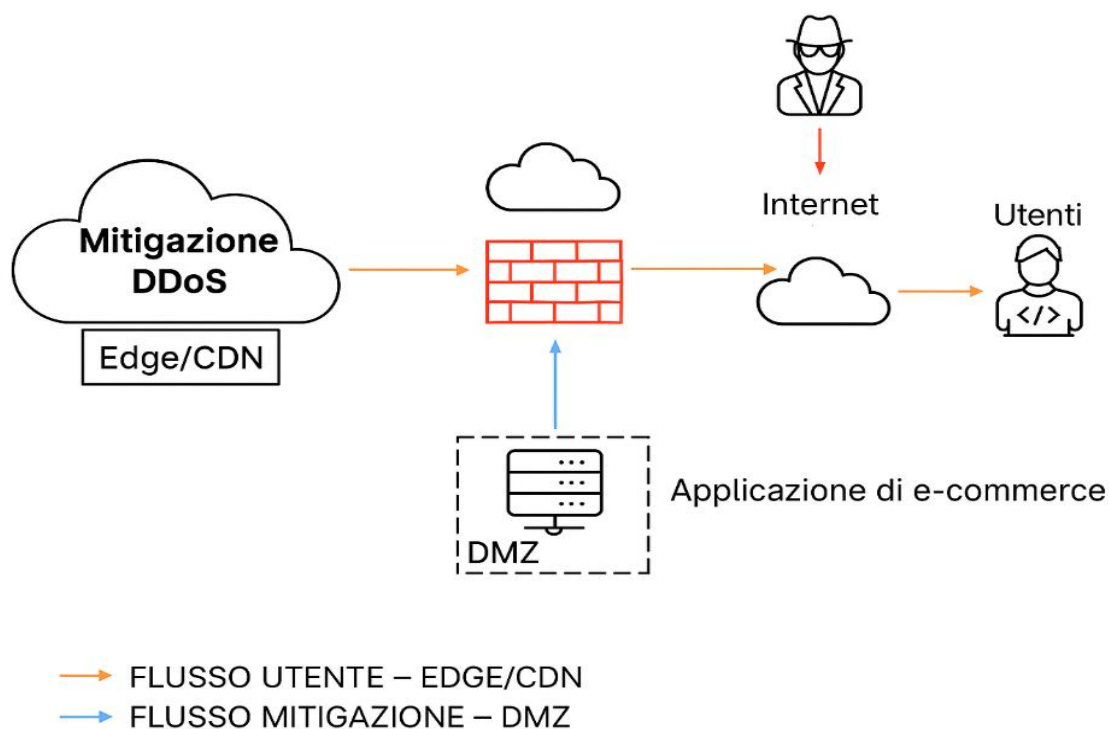
Misura	Descrizione
Firewall perimetrale avanzato	Blocca IP noti, limita connessioni, protegge da flood TCP/UDP
Rate limiting sul server web	NGINX / Apache possono limitare richieste per IP
Timeout bassi + keepalive off	Riduce occupazione risorse da client zombie
Caching (reverse proxy)	NGINX o Varnish cache per servire pagine senza colpire backend
Protezione ISP (anti-DDoS)	Alcuni provider bloccano attacchi upstream (es. Aruba, OVH, Hetzner)
Monitoraggio manuale di rete	Uso di iftop, nload, tcpdump, netstat

Esempio tecnico senza software (NGINX):

```
limit_req_zone $binary_remote_addr zone=one:10m rate=5r/s;

server {
    location / {
        limit_req zone=one burst=10;
    }
}
```

} #Questo limita ogni IP a 5 richieste/secondo con un piccolo burst.



Protezione anti-malware senza software commerciale

1. Limitazione privilegi

Misura	Descrizione
Utenti non root	L'applicazione web nella DMZ non va eseguita da root
Sudo ristretto	Solo utenti autorizzati possono usare comandi critici
Chroot / sandbox	Isola i processi in ambienti chiusi

2. Hardening file system

Azione	Descrizione
No esecuzione in /tmp	Monta /tmp con opzione noexec per evitare esecuzione da lì
Controllo permessi file	Solo lettura per file pubblici, scrittura solo dove necessario
Disabilita upload arbitrari	Se accetti file, verifica estensione, MIME type, firma hash

3. Pulizia del codice

Protezione	Come
Disabilita eval() in PHP	Spesso usato da web shell
Rimuovi upload.php inutili	Controlla se sono vulnerabili (es. <?php system(\$_GET['cmd']))
Sanifica input/parametri	Mai fidarsi di ciò che viene da utente (usare htmlspecialchars, escapeshellcmd, ecc.)

4. Monitoraggio attività sospette (manuale o script)

Cosa controllare	Comando / metodo
File modificati di recente	find /var/www -mtime -1
File PHP sospetti	grep -r "eval(" /var/www
Connettività anomala	netstat -tulnp / ss -tulnp
Cron job non noti	crontab -l / ls /etc/cron*
File in /tmp, /var/tmp	ls -l

5. Backup offline

- Mai tenere i backup sullo stesso disco del server
- Usa storage esterni montati solo durante l'operazione
- Automatizza backup giornalieri con rsync + cron

6. Strumenti open source leggeri

Strumento	Funzione	Note
ClamAV	Antivirus CLI	Scansione manuale/cron, leggero
Chkrootkit	Rilevamento rootkit	Identifica file sospetti a livello root

Strumento	Funzione	Note
Lynis	Audit di sicurezza completo	Analisi configurazioni, hardening
Tripwire / AIDE	Integrità file system	Allerta modifiche a file sensibili

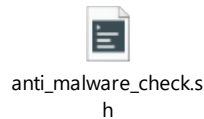
Checklist minima anti-malware (senza software commerciale):

- Nessuna esecuzione in /tmp
- Nessun utente ha privilegi inutili
- Upload file sanitizzato e limitato
- Backup esterni e sicuri
- Controlli cron settimanali con script
- File PHP auditati per comandi sospetti
- ClamAV o Lynis installato

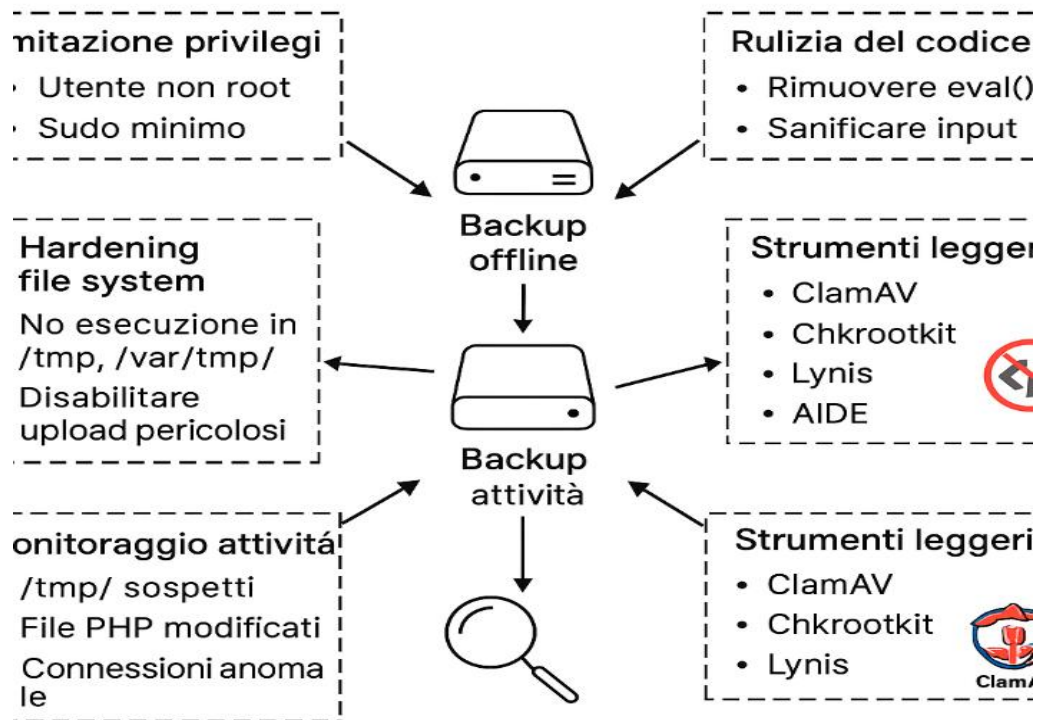
In sintesi: soluzione minima efficace

- Attiva Cloudflare Free/Pro
- Configura rate limiting e caching su NGINX
- Chiedi al tuo provider se offre protezione DDoS base
- Isola la DMZ da qualsiasi impatto sulla rete interna
- Analizza log in caso di traffico anomalo

lo script di controllo automatico anti-malware:



MITIGAZIONE ANTI-MALWARE



Impatto pratico (dallo scenario iniziale)

- Se il sito rimane **offline per 10 minuti**, e gli utenti spendono **1.500 €/minuto**, La perdita è: **15.000 € per ogni attacco riuscito**.

Ho creato questo report con l'intenzione di offrire quante più soluzioni possibili adatto ad ogni tipo di disponibilità, mi scuso in anticipo per le immagini se poco chiare e dettagliate.